

Enterprise v2.3 security architecture, authorized red-team simulation and purple-team roadmap for CTO and security committee review.

Release v2.3 · Enterprise Security Committee Edition · 2026-07-20

Classification: Internal Architecture & Security Review **Assessment mode:** authorized, local, non-destructive
Audience: CTO, Security Committee, Product Infrastructure and Engineering Leadership

1. Executive Summary

Technical conclusion — strong product security foundation, four High gaps block enterprise-grade assurance

Athena 已建立一条明显优于普通 AI 应用的安全主链：Passkey/OPAQUE 与服务端 Session V2、资源级授权、设备签名、AES-256-GCM/HKDF、内容对象信封加密、Chat Hash Chain、Ed25519 审计检查点、Sync V2 版本/Hash/Outbox/cursor，以及运行时 drain/DLQ/reconcile。50 个测试套件、275 项聚焦测试全部通过；当前 1,038 条 Chat 的 prompt/response 全部加密，Chat 链断裂为 0，263 个 Sync 节点与 186 个投影没有 Hash、权限或正文冲突。

但是，系统尚不能被评为“企业安全完成态”。本次发现 0 个 Critical、4 个 High、5 个 Medium、2 个 Low。四个 High 分别位于：(1) WebSocket 未统一执行权威 Session V2；(2) Collector 开发态接受调用方 absolutePath，已在授权本机用公开文件安全复现；(3) Collector 容器挂载与环境变量范围过大；(4) RAG 内容缺少 untrusted/taint/provenance 边界，可诱导 workspace rag-memory 持久化污染。

综合评分 **7.4/10**。结论是“安全架构方向正确、数据保护成熟、AI 与长连接边界需要 P0 闭环”。报告不把外部 PostgreSQL/NATS/S3/KMS 适配代码等同于生产证明，也不把开发态问题隐瞒为‘只影响开发’：开发环境往往拥有最宽数据与密钥可见性，必须按真实信任边界修复。

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Overall security score

7.4

Weighted current security score; not a compliance certification.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Critical findings

0

Confirmed Critical findings in the authorized review.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

High findings

4

High findings requiring immediate ownership.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Tests passed

275

Focused security, Agent, Sync, transport and storage tests passed.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Sync integrity

100%

Reviewed Sync projections with no hash, permission or projection conflict.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Encrypted Chat rows

1.04K

Current Chat rows with encrypted prompt and response.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Confirmed and conditional finding distribution

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

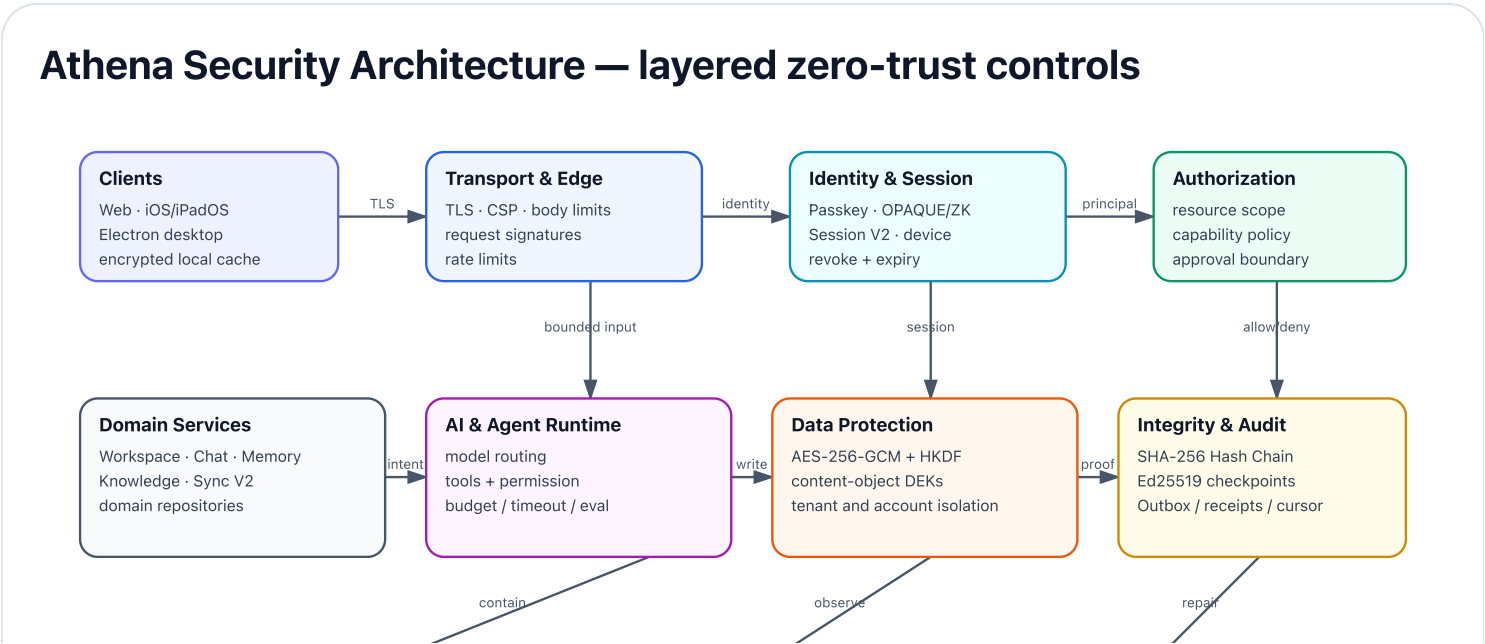
Severity	Findings
Critical	0
High	4
Medium	5
Low	2

Security committee decision

- 允许继续本地开发与受控灰度：现有 REST、Chat SSE、Sync V2 数据模型、加密存储和对象层无需推倒重写。
- 不允许在四个 High 未关闭前声明企业安全就绪：特别是独立 Realtime Gateway、公开 Collector 或高权限插件/Agent。
- 修复策略必须无感兼容：WS 使用短期 ticket 的双读迁移；Collector 使用服务端签发的 opaque handle；Memory 先进入候选态，不删除现有用户记忆。
- 安全与同步继续解耦：实时传输丢失可补拉；身份吊销和授权失败必须立即 fail-closed。

2. Security Architecture Diagram

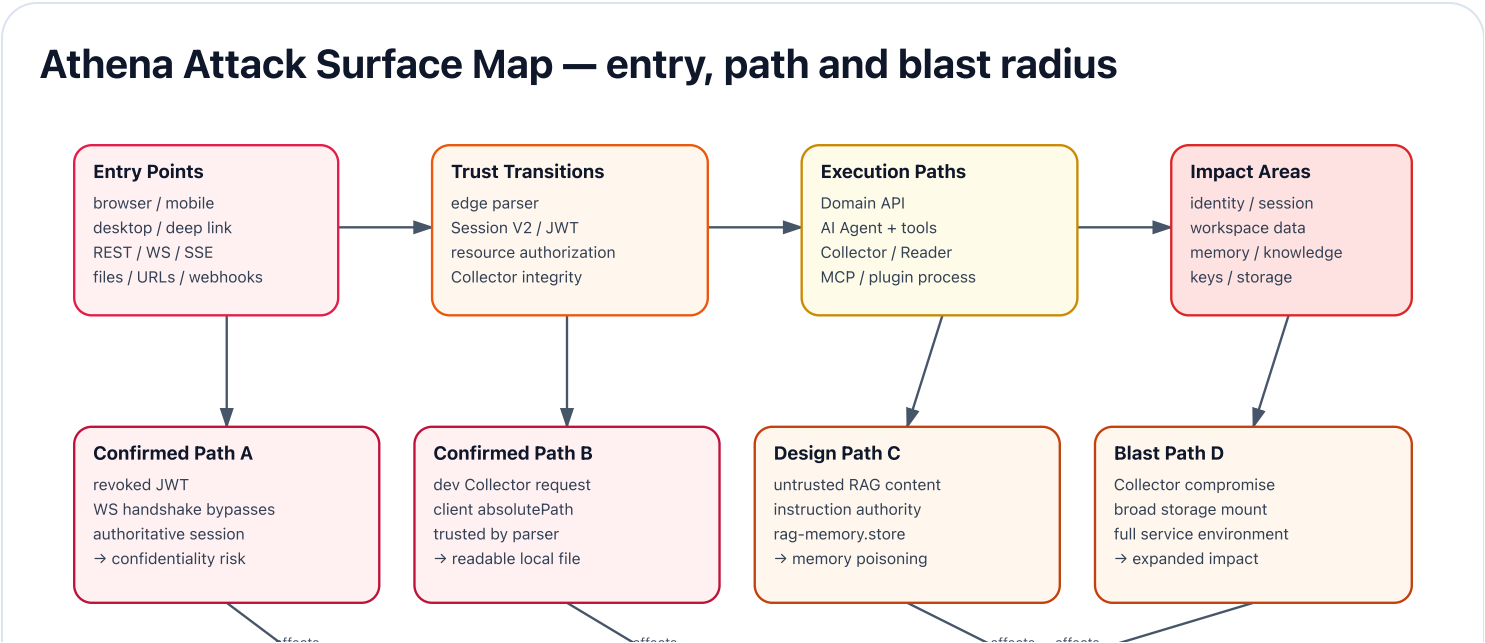
Athena 的 Zero Trust 边界应贯穿每一次请求和每一条长连接：客户端或内部服务的网络位置都不构成信任；身份、设备、资源、操作能力和数据用途分别授权。加密解决机密性，Hash Chain/签名解决完整性，Outbox/cursor 解决可靠恢复——三者不能互相替代。



Existing control chain

1. 客户端使用 TLS；Web 使用 sessionStorage bearer token 与不可导出 WebCrypto 缓存密钥，iOS 使用 Keychain ThisDeviceOnly 与 CryptoKit。
2. API 入口执行内容类型/体积限制、必要的原文 Hash/签名、登录限流、Session 与资源权限。
3. AI/Agent 的模型输出不直接产生授权；工具必须再经过 capability、approval、文件/网络/时间/成本边界。
4. 领域表是业务权威；Content Object 只承载 Blob；Sync Tree 只承载版本、Hash、游标与引用。
5. Security Ledger 与 Chat Chain 提供篡改证据；Runtime Coordinator、lease/DLQ/sweeper/reconcile 提供自恢复。

3. Attack Surface Map



Athena Attack Surface Inventory

Entry points, existing controls, residual exposure and lifecycle.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Surface	Entry & lifecycle	Current controls	Residual exposure
AI Agent / MCP / plugins	prompts, RAG context, tool calls, scheduled jobs · Lifecycle: invocation / job / agent session	capability manifests, approval, timeout, tool policy, budget scaffolding	untrusted context taint and workspace-memory confirmation incomplete
Collector / Reader	URL fetch, files, archives, raw text · Lifecycle: bounded task / temporary directory	SSRF, DNS-rebinding, redirect, archive, size, timeout and concurrency guards	development absolutePath trust and excessive container mounts/environment
Data plane	Main/Auth DB, content objects, vector DB, graph, local filesystem · Lifecycle: domain-defined retention	AEAD, HKDF, DEK envelope, tenant scope, foreign keys, hashes	external KMS/WORM/multi-node proof outstanding
Electron desktop	renderer IPC, local service, updater, child processes · Lifecycle: application and supervised children	contextIsolation, nodeIntegration off, sandbox, signed-update policy	desktop offline authority and cloud authority require explicit mode separation
iOS / iPadOS	REST, WS, APNs wake, local cache · Lifecycle: device-bound, logout/account isolated	Keychain ThisDeviceOnly, CryptoKit AES-GCM, complete file protection, device signatures	authenticated revoke/kill/network-switch E2E not completed in this review
REST API	602 route declarations across 73 endpoint files · Lifecycle: request / session	body classes, session middleware, resource AuthZ, rate limiting, request signing	17/12 reviewed allowlist entries require continuing ownership
Supply chain / CI	npm packages, container images, GitHub Actions · Lifecycle: build / release	full-SHA actions, reachable Critical gate, tests and static audits	165 raw High advisories; images not all digest-pinned; no installed secret scanner
Web / browser	REST, Chat SSE, Sync WS, deep links, cached state · Lifecycle: per tab / account / session	CSP, TLS, sessionStorage token, non-extractable WebCrypto cache key, encrypted IndexedDB	WS query-token exposure; XSS remains a bearer-token concern
WebSocket / SSE	broadcast, Agent, crypto and chat streams · Lifecycle: long-lived connection	JWT identity, scope routing, origin checks, signed high-risk Agent messages	authoritative Session V2 not uniformly enforced at WS handshake

Principal attack-surface observation

最危险的边界不是公开 REST 本身，而是‘被认为已经在内网或开发态’的旁路：长连接握手、Collector 本地文件入口、解析容器的挂载/环境，以及被模型视为普通上下文的外部文档。大厂级治理要求这些旁路与主链路使用同一身份和最小权限策略。

4. Threat Model

本评审按资产—信任转换—攻击者能力—可观测性—恢复路径建模。严重性同时考虑可利用性、数据/身份影响、是否持久化以及是否跨租户。没有可利用路径的外部环境缺失记录为 assurance gap，不伪装成漏洞。

Threat Model

Abuse cases prioritized by trust transition, asset and realistic impact.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Threat & actor	Asset & attack path	Control & gap	Likelihood & impact
T01 · credential thief	Asset: account session and synchronized data · Path: stolen bearer token → long-lived WebSocket	Control: REST Session V2, device trust · Gap: WS handshake bypasses authoritative session	Likelihood: medium · Impact: high
T02 · local-network or malicious web origin	Asset: development host files · Path: Collector parse request → caller-supplied absolutePath	Control: SSRF and archive guards · Gap: dev integrity bypass, permissive CORS/bind, trusted path	Likelihood: high in dev · Impact: high
T03 · malicious document or web content author	Asset: workspace memory and Agent behavior · Path: indirect prompt injection → rag-memory.store	Control: tool policy and high-risk approvals · Gap: no taint/provenance/forced confirmation for workspace vector memory	Likelihood: medium · Impact: high
T04 · compromised parser dependency	Asset: databases, objects and service credentials · Path: Collector process compromise → broad RW storage and environment	Control: non-root, cap-drop, read-only rootfs · Gap: service mount and secret scope are too broad	Likelihood: low-medium · Impact: high
T05 · unauthenticated recon	Asset: runtime topology and failure state · Path: public detailed readiness	Control: no business data in response · Gap: host/worker/component detail is exposed	Likelihood: high · Impact: medium
T06 · internal network attacker	Asset: cross-instance event integrity · Path: NATS credential theft or transport interception	Control: Outbox authority, eventId dedupe, obfuscated subjects · Gap: TLS/mTLS/ACL/event signature not enforced by adapter	Likelihood: conditional · Impact: medium-high
T07 · malicious dependency or build compromise	Asset: application and CI · Path: reachable vulnerable package or mutable image tag	Control: Critical gate, SHA-pinned Actions · Gap: High backlog, SBOM/VEX and digest pinning incomplete	Likelihood: medium · Impact: medium-high
T08 · privileged insider or host compromise	Asset: security evidence · Path: modify database and local ledger/archive	Control: Hash Chain + Ed25519 checkpoints · Gap: external immutable archive/SIEM disabled by default	Likelihood: low-medium · Impact: high

Crown-jewel assets

- 身份权威：AuthSession、Passkey 公钥、设备绑定、恢复与吊销状态。
- 用户数据：Chat、Workspace、文档、附件、长期记忆、向量与图谱。
- AI 控制权：系统提示、Agent 角色、工具能力、预算、插件服务身份。
- 密钥与证据：Key Custody、DEK 封装、设备签名密钥、审计链与检查点。
- 同步权威：stateVersion、Outbox seq、mutation receipt、cursor 与权限投影。

5. Red Team Attack Simulation

所有动态测试都在用户授权的本地开发环境完成，使用非破坏性输入。没有读取或输出秘密材料，没有写入恶意长期记忆，没有修改真实业务数据。复现路径在报告中保持为防御团队可行动的最小信息，不提供可直接滥用的武器化载荷。

Authorized Red Team Simulation

Non-destructive simulation and code-path confirmation; no secret or user content was exposed in the report.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Scenario & result	Technique & evidence	Risk	Recommendation
Audit tampering · Result: detectable	Technique: ledger chain/checkpoint verification · Evidence: 13 entries, 4 Ed25519 checkpoints, 0 verification failures	pass with gap	export to immutable external archive and alert on archive lag
Authentication bypass · Result: blocked	Technique: protected REST access without credentials · Evidence: Sync manifest, Vault and mutation endpoints returned 401	pass	retain centralized route audit and sensitive authoritative session reads
Collector local file read · Result: confirmed	Technique: authorized safe file path supplied to development parse API · Evidence: Collector returned parsed public repository file content	High	opaque handles only, realpath root check, loopback bind and integrity in dev
Horizontal / vertical authorization · Result: blocked in tested matrix	Technique: resource-scope and temporary-token access tests · Evidence: resource-access, temporary-token and static route audits pass	pass	add authenticated cross-tenant runtime E2E to complement static assurance
JWT / recovery abuse · Result: mostly blocked	Technique: algorithm, token replay, recovery and single-use review · Evidence: sessions, rate limits and recovery tests pass; explicit algorithm pin remains	Low	pin algorithm; deadline and telemetry for legacy token path
Oversized / chunked body · Result: blocked	Technique: send payload beyond ordinary 3 MiB class · Evidence: 413 before business handling with structured limit response	pass	continue heap and compressed-body regression tests
Session revocation replay · Result: confirmed design bypass	Technique: trace revoked/stolen JWT through broadcast, Agent and crypto WS handshakes · Evidence: WS paths decode JWT/load user without AuthSession validation	High	shared WS authenticator, short-lived ticket, periodic revalidation and revoke-close
SSRF to loopback · Result: blocked	Technique: Collector URL request targeting API loopback · Evidence: destination policy rejected loopback	pass	return explicit denial status and preserve redirect/DNS revalidation
Sync event injection/replay · Result: blocked in tested paths	Technique: duplicate, stale, conflicting and unsigned mutation tests · Evidence: version/hash/receipt/signature/cursor tests pass; 0 projection mismatch	pass	close WS session gap and run authenticated multi-device chaos

Verified runtime observations

- Frontend、API、Collector 健康检查均为 HTTP 200；TLS 1.1 被拒绝，TLS 1.2/1.3 可用。
- API 返回 DENY frame policy、nosniff、严格 referrer policy、Permissions-Policy 与 object-src 'none' / frame-ancestors 'none' CSP。

- 未认证 Sync manifest、Vault、mutation batch 均返回 401。
- 普通 JSON 超过 3 MiB 在业务处理前返回结构化 413。
- Collector loopback SSRF 被目的地址策略阻止。
- Collector 开发态本地文件读取已用仓库公开文件安全复现，证明它不是仅靠静态推断的理论问题。

6. AI Security Assessment

Athena 的 Agent 安全优点是能力检查在工具侧，而不是依赖模型‘自觉’；高风险文件/工具和账户级 save_memory 已有明确审批边界。主要缺口是进入模型的 RAG/网页/文件内容尚未被统一标记为不可信数据，且 workspace rag-memory.store 没有复用账户记忆的‘显式当前用户意图 + 强制审批 + 候选确认’策略。

AI & Agent Security Assessment

Model behavior is never treated as an authorization decision; tool and memory sinks need their own policy.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Area & priority	Current control	Attack & assessment	Gap
Agent evaluation · Medium	usage/budget/eval data structures and tests	Attack: quality or safety regression passes release · Assessment: observe-ready	production datasets, thresholds and enforcement maturity
Agent privilege escalation · Medium	user/workspace context and scoped capability checks	Attack: Agent crosses workspace, role or device boundary · Assessment: no confirmed bypass in focused tests	continuous cross-tenant adversarial corpus absent
Data exfiltration · Medium	resource AuthZ, encrypted storage, tool restrictions	Attack: malicious context asks tool to reveal hidden/system/private content · Assessment: bounded but not formally proven	egress DLP, canary documents and taint-to-sink policy needed
Jailbreak · Medium	provider/system policies and tool-side authorization	Attack: model output violates behavioral policy · Assessment: model-dependent	no release-gated adversarial safety/eval corpus
Memory poisoning · High	account save_memory requires explicit intent and approval	Attack: RAG content induces rag-memory.store into workspace vector namespace · Assessment: confirmed design gap	workspace store lacks equivalent forced approval and provenance
Prompt injection · High	system/tool prompts and capability boundaries exist	Attack: direct or indirect instructions attempt to override policy · Assessment: partial resistance	no centralized untrusted-content taint/provenance layer
Tool abuse · Medium	tool policy, approvals, timeouts and capability broker	Attack: request unauthorized file/network/high-risk tool · Assessment: strong for covered tools	plugin isolation and Secret Broker enforcement are not universal

Target AI trust pipeline

External content → provenance + taint label → retrieval policy → untrusted-data envelope → model → proposed action → capability + user approval → isolated tool → audited result → candidate memory → confirmation → active memory

任何文档、网页、插件返回或模型输出都不能自动升级为系统指令。Memory 是高价值持久化 sink，应和文件写入、网络访问、Secret 使用同等对待。

Future AI OS security requirement

Personal AI OS 需要可解释的记忆同意、来源、衰减、删除、跨 Workspace 边界和组织策略；Multi-Agent 架构还需要可验证的 Agent 服务身份、委托链、最小能力、预算与责任归属。不要用通用 CRDT、ZKP 或门限签名掩盖尚未完成的基本授权和隔离。

7. Identity Security Review

Identity & Authorization Review

Zero-trust identity controls and the long-lived-channel exception.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Control & rating	Implementation	Verification	Residual gap
Account deletion/revocation · good design	persistent idempotent workflows and session revision reconcile	failure/recovery paths present	external multi-store chaos proof remains
Authorization · strong	route middleware, resource ownership, workspace role, capability policy	338-route hardening audit and resource tests passed	allowlist ownership and dynamic cross-tenant E2E
Device trust · strong with gap	P-256 signing, nonce/timestamp/body hash, client identity	native signing/replay tests passed	socket revalidation and device-revoke E2E incomplete
Login abuse · strong locally	persistent IP/identifier/combined buckets and dummy async bcrypt	rate-limit behavior tests passed	production distributed limiter topology still needs external proof
Primary authentication · strong	Passkey, OPAQUE/ZK, password/SSO/invite compatibility	focused auth suites passed	phishing-resistant methods should be preferred and measured
Server session · material gap	AuthSession sid/jti, idle/absolute expiry, token version, revoke	REST and sensitive-session tests passed	not reused by all WebSocket handshakes
Token handling · needs improvement	Web sessionStorage, iOS Keychain, no new password-bearing JWT	JWT fallback and storage design reviewed	query-string token on Web WS; algorithm pin cleanup

High finding: authoritative identity stops at the WebSocket boundary

REST 的 Session V2 能检查 sid、idle/absolute expiry、tokenVersion、吊销和敏感操作的权威状态；但 broadcast、Agent 与 crypto WebSocket 的握手路径仍以‘JWT 能解码并能加载用户’作为主要判断。结果是旧 Token 被吊销后，可能在 JWT 自身过期前重新建立或维持连接。

推荐迁移：REST-authenticated one-time WS ticket (30–60s) → handshake binds sessionId/clientId/device → socket expiry timer + periodic authoritative revalidation → revoke/device event closes active sockets。旧客户端在短过渡期双读，但禁止继续在 URL 中发送长期 bearer token。

8. Data Security Review

Data Security Review

Authority, confidentiality, integrity, isolation and recovery evidence by domain.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Domain & integrity	Protection & isolation	Recovery	Gap
Auth/session data · Evidence: quick_check and foreign_key_check pass	Protection: separate Auth DB, least-privilege target roles, encrypted sensitive fields · Isolation: authUserId authority; no cross-DB joins	revision fingerprint/reconcile and repair workflow	external PostgreSQL cutover proof
Chat and messages · Evidence: 1,038/1,038 encrypted; invalid chains 0	Protection: AES-256-GCM, hash-chain metadata, content-object references · Isolation: workspace/thread ownership and attachment authorization	rebuild/audit and object reconciliation	external object store/KMS proof
Content objects · Evidence: checksum and staging→ready transaction	Protection: per-object random DEK, streaming AEAD, wrapped DEK, HMAC tenant fingerprint · Isolation: authorization on every download	staging GC, delayed delete, reference recount	external S3 object-lock and KMS proof
Knowledge/vector · Evidence: 695/695 vector text rows encrypted	Protection: encrypted document store, vector text encryption · Isolation: workspace/vector namespace	re-embed/re-index from authorized source	prompt-injection provenance and data-residency policy
Long-term memory · Evidence: candidate/confirmed structure	Protection: encrypted values and scoped synchronization · Isolation: user/workspace ownership	delete/reconcile	workspace rag-memory confirmation and provenance
Security audit · Evidence: 13 entries / 4 checkpoints / 0 failures	Protection: SHA-256 chain and Ed25519 checkpoints · Isolation: administrative/security access	verify and archive retry	external immutable archive disabled by default
Sync metadata · Evidence: 263 nodes; 186 projections; 0 hash/conflict findings	Protection: account/device cursor partition, no secrets or Blob payloads · Isolation: permission checked on manifest, pull and event	cursor replay, reconcile, tombstone and hash repair	current dev rollout disabled

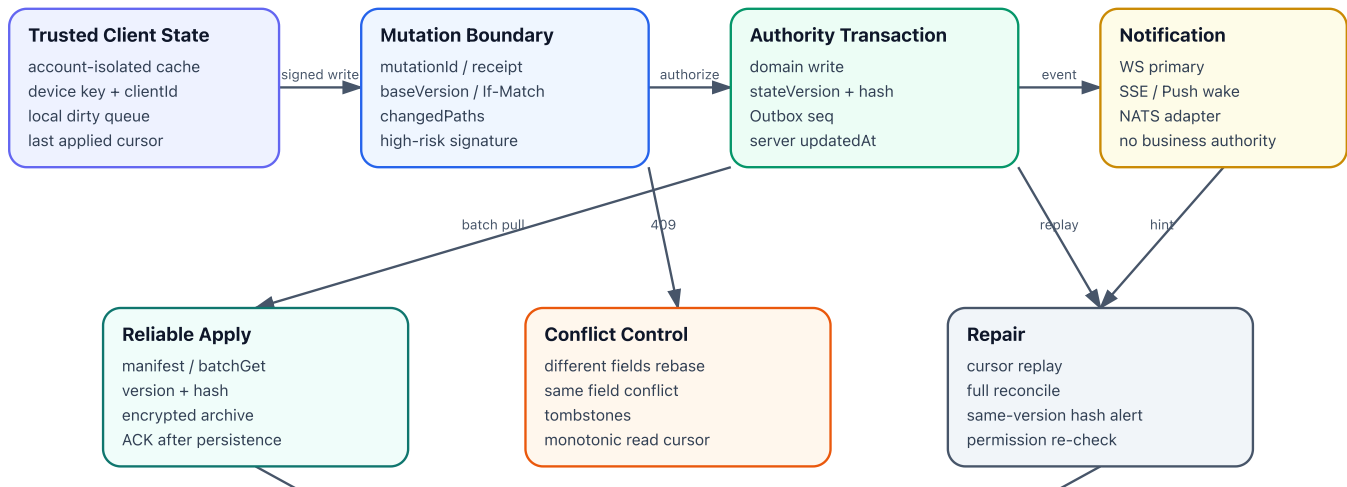
Verified protection evidence

- Main/Auth SQLite quick_check=ok，外键违规为 0。
- 1,038/1,038 条 Chat prompt 与 response 已加密；1,038 条 crypto metadata 完整，chainInvalid=0。
- 文档存储 31 条、向量缓存 30 条、LanceDB 文本 695/695 条均在当前审计中显示加密覆盖。
- Content Object 以独立随机 DEK、AEAD、checksum 和 staging→ready 状态隔离 Blob；Chat 大对象治理使数据库相对迁移前基线缩小约 90%。
- 安全账本 13 条记录、4 个 Ed25519 检查点，验证失败 0。

这些结果证明当前本地数据保护链健康，但不能替代外部 KMS、对象锁、备份恢复和数据驻留演练。

9. Cross-device Synchronization Security

Sync V2 Security — consistency proof is separate from real-time transport



Attack-resistance assessment

- 恶意客户端不能自行提升服务端版本；Mutation 使用 mutationId、baseVersion、changedPaths、receipt 与必要的设备签名。
- 乱序或重复事件不会直接重复业务副作用；客户端只在业务缓存、descriptor、加密 Archive 与 cursor 全部可靠落盘后 ACK。
- WS/SSE/APNs 是提示与唤醒链路，Outbox seq、event replay、Manifest/BatchGet、stateVersion/hash 才是恢复依据。
- 权限必须在发送与补拉时重查；安全/权限/Session/权益不得由陈旧缓存授予。
- 当前审计检查 263 个节点和 186 个投影，未发现权限、正文、Hash 或投影冲突。

Merkle Tree、通用 CRDT 与 Vector Clock 当前未部署。 这不是安全缺失：263 节点规模下 version+hash+cursor 已足够。若未来为协同正文引入 CRDT，必须同时设计 actor identity、每操作授权、tombstone/DoS 上限、签名快照和服务端准入；Merkle 只能优化对账，不能代替授权或消息签名。

当前最大同步安全缺口并不在状态树算法，而在长连接身份生命周期：被吊销的 Session 必须同时关闭/拒绝 WS，并确保未授权 scope 立即移除。

10. Infrastructure Security Review

Infrastructure Security Review

Runtime, deployment, distributed transport, observability and CI/CD controls.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Component & risk	Strengths	Finding / assurance gap	Required action
API runtime · Medium	request limit classes, graceful drain, readiness, structured errors	detailed public readiness leaks topology	minimal public health; authenticated internal diagnostics
CI/CD · Medium	full commit SHA for Actions; reachable Critical=0 gate	165 raw High advisories; incomplete SBOM/VEX/image digests	owner+expiry policy, reachability, SBOM and immutable release inputs
Collector · High	non-root, cap-drop, read-only rootfs, SSRF/archive/timeout/size guards	dev absolutePath trust; broad RW storage and full environment	opaque handles, narrow mounts/env/egress, loopback dev bind
Containers · High	sandboxing and least Linux capabilities in several services	Collector mount/environment violate process-level least privilege	service-specific identity, filesystem and network policy
Database · Assurance	SQLite integrity clean; PostgreSQL schemas/adapters and pool roles	external managed PostgreSQL not exercised here	staging cutover/rollback/lock/connection chaos
NATS JetStream · Medium conditional	Outbox authority, durable adapters, eventId dedupe, readiness behavior	TLS/mTLS/ACL not enforced in adapter	production-only secure scheme, workload identity and ACL
Observability · Medium	OTel/Prometheus-compatible instrumentation and correlation design	no external persistent SOC/SIEM evidence in local runtime	deploy collector/storage/alerts and incident runbooks
Secrets / keys · Assurance	Key Custody, canary validation, provider abstraction, no secret output	external KMS/HSM not production-proven	KMS/Vault staging and rotation drill without changing current keys

High finding: Collector isolation violates least privilege

Collector 已有很好的请求级 SSRF、DNS 重绑定、重定向、文件大小、超时、并发和 archive 防护，也使用 non-root/cap-drop/read-only rootfs。但部署仍把过大的服务端存储目录以读写方式挂入，并继承广泛的服务环境。解析器属于高风险供应链边界，一旦出错，进程级最小权限必须限制其只能看到本任务输入、输出与有限对象存储凭据。

推荐把 Collector 拆为‘控制 API + 隔离 Worker’，每任务独立临时目录和短期服务凭据；Main/Auth DB、Key 文件和其他服务 Secret 均不得挂载或注入。

Supply-chain posture

当前门禁满足 reachable Critical=0，GitHub Actions 使用完整 commit SHA；但原始 High advisory 仍为 Server 114、Collector 40、Frontend 11。大厂级门禁应以 reachability、owner、隔离、到期时间和回归共同决策，而不是简单忽略或强制大版本升级。发布镜像需要 digest pin，CI 需要 SBOM/CycloneDX、VEX、SCA、Secret scanner 与可追溯 provenance。

11. Vulnerability Report

Vulnerability Report

Deduplicated findings, evidence confidence, ownership and remediation target.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

ID & severity	Finding & evidence	Vector & impact	Remediation, owner & target
ATH-SEC-2026-001 · High	WebSocket handshakes bypass authoritative Session V2 · Evidence: confirmed code path	Vector: revoked or stolen JWT reused on broadcast/Agent/crypto sockets · Impact: session revocation may not terminate confidentiality or socket access until JWT expiry	shared authoritative WS auth, short-lived ticket, token/device binding, periodic revalidation and revoke-close · Owner: Identity + Realtime · Target: 0–7 days
ATH-SEC-2026-002 · High	Development Collector accepts caller-controlled absolutePath · Evidence: safely reproduced on a public repository file	Vector: unauthenticated local/dev parse request points to Collector-readable file · Impact: arbitrary readable local file exposure within Collector OS permissions	remove field from public DTO; opaque staging handles; realpath root check; loopback bind; dev integrity · Owner: Collector · Target: 0–7 days
ATH-SEC-2026-003 · High	Collector has excessive storage and environment blast radius · Evidence: confirmed compose/configuration	Vector: parser or dependency compromise · Impact: access to Main/Auth data, objects, key files or unrelated service credentials	narrow RO/RW mounts, scoped service identity, Secret Broker, egress allowlist and separate network · Owner: Platform Security · Target: 0–14 days
ATH-SEC-2026-004 · High	Indirect prompt injection can poison workspace vector memory · Evidence: confirmed design gap; not used to write real malicious content	Vector: malicious document/web context induces rag-memory.store · Impact: persistent attacker-controlled context can alter future Agent decisions	untrusted-data envelope, provenance/TTL, explicit current-turn intent, forced approval and candidate→confirmed activation · Owner: AI Platform · Target: 0–14 days
ATH-SEC-2026-005 · Medium	Public readiness exposes internal runtime detail · Evidence: confirmed runtime probe	Vector: unauthenticated /ready or /api/ready · Impact: reconnaissance of host, workers, queues and component failure state	minimal public status; authenticated internal diagnostic endpoint · Owner: Platform · Target: 30 days
ATH-SEC-2026-006 · Medium	NATS transport does not enforce production trust controls · Evidence: conditional code/config review	Vector: internal interception or service credential compromise · Impact: event observation/injection/redelivery pressure in distributed deployment	TLS/mTLS, CA validation, workload identity, subject ACL and optional Ed25519 event envelope · Owner: Realtime Platform · Target: 30 days before production NATS
ATH-SEC-2026-007 · Medium	High-severity supply-chain backlog remains · Evidence: Critical reachable=0; raw High server 114, Collector 40, frontend 11	Vector: reachable vulnerable dependency or mutable image input · Impact: server, Collector or frontend compromise depending on reachability	upgrade/disable reachable paths, SBOM/VEX, owner+expiry, image digest and secret scanning · Owner: Developer Platform · Target: 30–90 days
ATH-SEC-2026-008 · Medium	Security ledger lacks mandatory external immutable archive · Evidence: chain valid; archive disabled by default	Vector: host or privileged database compromise · Impact: local evidence can be deleted or withheld despite tamper detection	WORM/Object Lock export, archive-lag alert, SIEM ingestion and recovery drill · Owner: Security Operations · Target: 30 days
ATH-SEC-2026-009 · Medium	Web broadcast token appears in WebSocket query string · Evidence: confirmed client implementation	Vector: proxy/browser/crash/access log captures URL · Impact: bearer-token disclosure and replay	single-use 30–60 second WS ticket or secure subprotocol/header; redact URLs · Owner: Web + Identity · Target: 0–30 days
ATH-SEC-2026-010 · Low	JWT algorithm and legacy token path need explicit closure · Evidence: code review; no bypass reproduced	Vector: configuration drift or indefinite migration compatibility · Impact: future verification ambiguity and expanded maintenance surface	pin allowed algorithm, persist deadline, usage telemetry and removal gate · Owner: Identity · Target: 90 days
ATH-SEC-2026-011 · Low	Development exposure and production-policy drift are not continuously asserted · Evidence: development runtime probe	Vector: development CORS/metrics/environment behavior reaches shared environment · Impact: information exposure or mistaken deployment posture	deployment-mode policy tests, loopback defaults and production conformance gate · Owner: Platform · Target: 90 days

Severity rule

Critical 要求已确认的跨信任边界远程完全接管、广泛密钥/租户数据泄漏或不可逆高影响路径；本轮未确认此类问题。
High 包括可复现的本地/开发边界读取、会话吊销绕过、持久 AI 记忆污染和高影响隔离失败。条件性外部分布式风险在未部署前列为 Medium，并设为上线阻断门禁。

12. Risk Matrix

Residual Risk Matrix

Likelihood and impact are qualitative architecture-review judgments, not actuarial probabilities.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Risk & residual	Likelihood, impact & inherent	Current controls	Treatment
R1 Session revocation gap on WS · Residual: High	Likelihood: 3/5 · Impact: 4/5 · Inherent: 12 High	JWT identity, resource scope, signed high-risk messages	immediate
R2 Collector local file read · Residual: High	Likelihood: 4/5 dev · Impact: 4/5 · Inherent: 16 High	process OS permissions, local/dev boundary	immediate
R3 Collector process compromise · Residual: High	Likelihood: 2/5 · Impact: 5/5 · Inherent: 10 High	non-root/cap-drop/read-only rootfs	immediate
R4 RAG memory poisoning · Residual: High	Likelihood: 3/5 · Impact: 4/5 · Inherent: 12 High	capabilities, tool policy and approvals elsewhere	immediate
R5 Distributed event trust · Residual: Medium	Likelihood: 2/5 conditional · Impact: 4/5 · Inherent: 8 Medium	Outbox authority and dedupe	before NATS production
R6 Supply-chain compromise · Residual: Medium	Likelihood: 3/5 · Impact: 4/5 · Inherent: 12 High	reachable Critical gate and tests	continuous 30–90 day burn-down
R7 Audit evidence loss · Residual: Medium	Likelihood: 2/5 · Impact: 4/5 · Inherent: 8 Medium	signed chain checkpoints	immutable off-host archive
R8 Sync forgery/conflict · Residual: Low–Medium	Likelihood: 2/5 · Impact: 4/5 · Inherent: 8 Medium	version/hash/receipt/device signature/AuthZ/reconcile	authenticated chaos and cohort gate

Current assurance coverage by domain

Source: Athena v2.3 security evidence snapshot

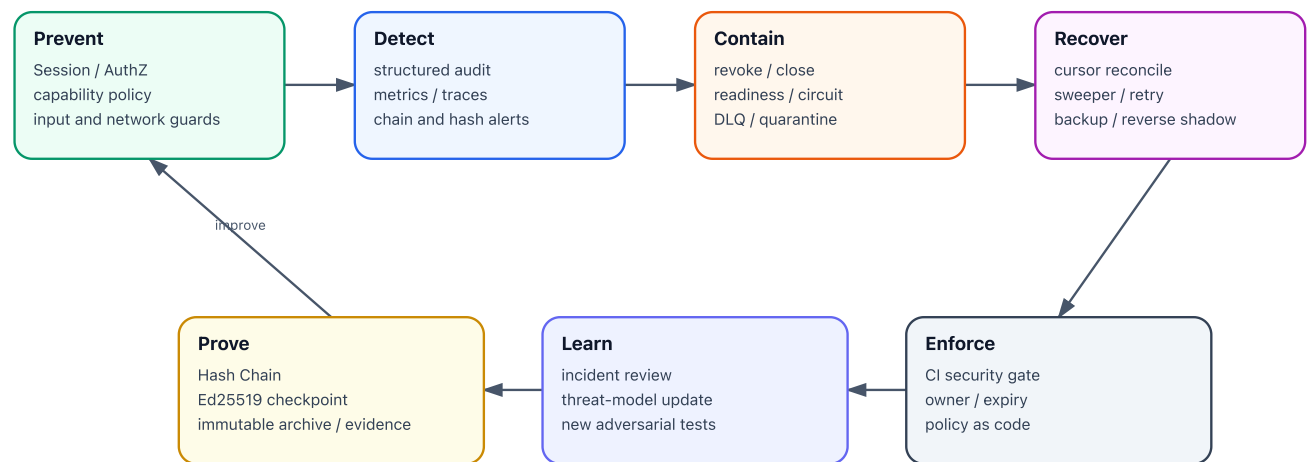
Tables: workspace_chats, sync_nodes, security_audit_ledger

Domain	Verified coverage
Identity & session	86%
Authorization & API	88%
Data protection	92%
Sync integrity	90%
AI / Agent security	65%
Infrastructure / operations	70%

覆盖率图是基于代码、测试、本机运行和外部环境证明的评审估计，不是统计置信区间。AI 与基础设施得分较低，原因是缺少持续对抗语料和外部多节点/SIEM/KMS 证明，而不是缺少代码文件。

13. Blue Team Defense Capability

Blue/Purple Team Closed Loop — detect, contain, recover, prove



Blue Team Capability Matrix

Prevention, detection, containment, response, recovery and evidence maturity.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Capability & maturity	Current state	Weakness	Next action
AI abuse detection · 2.5/5	tool policy, approvals, usage/eval scaffolding	no continuous prompt-injection/taint/DLP signal	adversarial corpus and taint-to-sink telemetry
Cryptographic operations · 4/5 local	Key Custody, canary, AEAD/HKDF, device signatures	external KMS/HSM and rotation drill pending	provider staging with no current-key modification
Identity detection · 3.5/5	login buckets, session records, revoke reasons, device identity	WS lifecycle not correlated to authoritative session	emit socket-session correlation and revoke-close metrics
Incident response · 3/5	structured errors, retries, sweeper, reconcile, rollback patterns	no demonstrated SOC paging/tabletop evidence	runbooks, on-call ownership and purple-team exercises
Runtime containment · 3/5	readiness, graceful drain, worker lifecycle, Collector guards	Collector service isolation violates least privilege	narrow process/container boundary
Security audit integrity · 4/5 local	hash chain + Ed25519 checkpoints	archive not mandatory/off-host	WORM export and verification alert
Supply-chain defense · 3/5	pinned Actions and reachable Critical gate	raw High backlog and incomplete SBOM/VEX/digests	risk-owned remediation and immutable inputs
Sync recovery · 4/5 design	Outbox lease/DLQ, cursor replay, full reconcile, hash repair	current local rollout disabled; large cursor lag is expected but unproven operationally	cohort SLO and authenticated fault drills

Self-operation and recovery assessment

Athena 已具备企业系统需要的自恢复骨架：Outbox/receipt lease、毒事件隔离/DLQ、Auth revision fingerprint 周期对账、Sync cursor/full reconcile、Content Object staging/GC、Runtime Coordinator drain、数据库/加密/Hash Chain 审计。缺口是这些能力还没有全部连接到持久化 SLO、跨组件 trace、告警分派、Runbook 和演练证据。‘自动重试成功’不是闭环；闭环必须能证明检测、限制爆炸半径、恢复权威状态并保存不可抵赖证据。

14. Purple Team Improvement Plan

Purple Team Improvement Roadmap

The roadmap fixes directly confirmed paths first and preserves compatibility through additive, feature-gated changes.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Horizon & priority	Changes	Benefit & gate	Rollback
30 days · P1	NATS TLS/mTLS/ACL/workload identity; WORM security archive; SIEM alerts; SBOM/VEX/image digest; authenticated multi-device revoke E2E	Benefit: enterprise distributed trust, investigation and supply-chain accountability · Gate: transport refuses insecure production configuration; archive lag alert; revoke under five seconds	return to in-process memory transport where topology permits
90 days · P1/P2	adversarial AI eval corpus; plugin container/Secret Broker enforcement; PG/NATS/S3 chaos staging; legacy JWT removal	Benefit: continuous AI assurance and production-scale proof · Gate: release safety thresholds; cross-tenant zero-leak suite; cutover/reverse-shadow drill	provider adapters and cohort switches; retain additive data
Immediate · 0–7 days · P0	authoritative WS handshake/revalidation/revoke-close; short-lived ticket; remove Collector public absolutePath; loopback bind and dev integrity; minimal public readiness	Benefit: closes two directly confirmed attack paths and reduces reconnaissance · Gate: revoked JWT cannot connect/remain; safe file proof returns deny; clients remain compatible	feature-gated WS ticket dual-read; Collector opaque-handle compatibility adapter
Immediate · 0–14 days · P0	Collector narrow mounts/env/egress; RAG taint/provenance, explicit intent, forced approval and candidate memory	Benefit: reduces parser blast radius and persistent AI compromise · Gate: tool/file/network/secret escape tests fail closed; poisoning corpus cannot activate memory	disable external parsing or workspace memory store, not security checks
Long term · Strategic	SPIFFE/SPIRE workload identity, managed KMS/HSM, data residency, multi-region recovery, continuous purple team and bug bounty	Benefit: five-year enterprise trust and platform ecosystem resilience · Gate: SLO/error budget, RTO/RPO, residency and cryptographic governance	region/workload identity staged adoption

Release, migration and rollback strategy

- 每项修复独立开关与可观测指标；先 shadow/dual-read，再小流量，再强制。
- WS ticket 迁移保留旧客户端短期兼容，但安全事件必须强制权威 Session 读。
- Collector 的旧 absolutePath 只允许 API 进程内部适配为 opaque handle；公共请求立即拒绝。
- Workspace memory 先保存候选和 provenance，再由用户确认激活；不自动删除现有记忆。
- NATS、KMS、WORM、PG 只在 staging 演练通过后启用；故障时回到现有权威链路，不丢 Outbox/领域数据。
- 测试循环遵循一次完整矩阵登记缺陷、修复后只重测相关项、全部关闭后最终完整门禁。

Required verification gates

1. 吊销 Session/设备后 5 秒内拒绝新 WS 并关闭已有 socket；URL/日志无长期 Token。
2. Collector 对绝对路径、符号链接、越界 realpath、跨任务 handle、浏览器来源和无签名调用全部 fail-closed。
3. Collector Worker 无法读取 Main/Auth DB、Key 文件或非本任务目录，网络只允许批准域。
4. 间接提示注入不能直接触发 memory/file/network/secret sink；所有候选 Memory 带 provenance、scope、TTL 和审批证据。

5. NATS 生产配置无 TLS/mTLS/ACL 时 not-ready；重复、乱序与伪造事件不产生业务副作用。
6. 安全账本归档延迟、链失败、登录异常、工具越权、Sync backlog 与对象校验失败均触发告警。
7. 供应链门禁保持 reachable Critical=0；High 必须有 owner、隔离和到期时间。

15. Standards Mapping

Standards Mapping

Reference mapping used for architecture review; this report does not assert formal certification.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Standard & assessment	Mapped domains	Evidence	Gaps
NIST CSF 2.0 · all functions represented	Govern, Identify, Protect, Detect, Respond, Recover	policy/tests, encryption, telemetry design, reconcile/rollback	external SOC evidence, immutable archive and exercises
NIST SP 800-207 Zero Trust · strong REST path; incomplete long-lived channel path	continuous identity, resource policy, device context, least privilege	Session V2, device signing, resource AuthZ	WS revalidation and workload identity
OWASP ASVS 5.0.0 · substantial controls; not a certification	authentication, session, access control, input, cryptography, API and configuration	275 focused tests, route audits, runtime probes	WS session lifecycle, Collector file boundary, external DAST/SAST
OWASP LLM Top 10 / LLMSVS / AISVS · partial	prompt injection, sensitive disclosure, supply chain, excessive agency, memory poisoning	capability/approval/tool timeout tests	taint/provenance, continuous adversarial eval and DLP
OWASP Top 10:2025 · reviewed	broken access control, security misconfiguration, injection, supply chain, logging	resource tests, body/SSRF guards, dependency gate, signed ledger	readiness exposure, Collector dev trust, dependency High backlog

Normative references

- [OWASP Application Security Verification Standard 5.0.0](#)
- [OWASP Top 10:2025](#)
- [NIST SP 800-207 Zero Trust Architecture](#)
- [NIST Cybersecurity Framework 2.0](#)
- [OWASP Top 10 for LLM Applications 2025](#)
- [OWASP LLM Verification Standard v2](#)
- [OWASP AI Security Verification Standard](#)

16. Final Security Score

Security evaluation scorecard

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Dimension	Score
Authentication Security	7.4
Authorization Security	7.8
Data Protection	8.5
AI Security	6.5
Infrastructure Security	6.9
Attack Resistance	7.1

Final Security Score

Scores are calibrated to current evidence and intentionally capped by the four High findings and missing external-production proof.

Source: Athena v2.3 security evidence snapshot

Tables: workspace_chats, sync_nodes, security_audit_ledger

Dimension	Score /10	Rationale
Data Protection	8.5	Comprehensive AEAD/HKDF/object encryption and integrity evidence; Collector blast radius and external KMS proof cap the score.
Authorization Security	7.8	Resource/capability controls and route audits are strong; Collector and WS boundaries bypass the intended control plane.
Authentication Security	7.4	Passkey/OPAQUE, Session V2 and rate limits are strong; WS session enforcement is a material gap.
Attack Resistance	7.1	Most tested abuse paths fail closed; four High findings prevent enterprise-ready assurance.
Infrastructure Security	6.9	Runtime and container controls exist, but Collector isolation, external SIEM and distributed trust remain unproven.
AI Security	6.5	Tool capabilities and approvals are promising; indirect injection, taint and memory confirmation are incomplete.

Final assessment: 7.4/10 — Strong product-grade foundation, not yet enterprise security complete

Athena 的 Data Protection 已接近企业强度，身份与授权主链也明显成熟；四个 High 集中在‘主链路之外的旁路’与 AI 持久化 sink。完成 0–14 天 P0 后，预计整体可进入约 8.2/10 的准企业区间；只有外部 staging 的多节点、KMS/WORM/SIEM、持续 AI 对抗和事故演练完成，才应声明 8.5+ 的企业安全成熟度。

17. Methodology, Evidence and Limitations

Evidence collected

- 扫描前后端、数据库、同步、缓存、认证、WebSocket、Workspace、Memory、Knowledge、Agent/MCP、iOS、Desktop、Docker、CI/CD 与运维配置。
- 执行 50 个聚焦套件、275 项测试，全部通过。
- 执行 Main/Auth 数据库完整性、加密覆盖、Chat Hash Chain、Sync shadow、Security Ledger、资源授权、桌面安全和供应链门禁审计。
- 启动真实本地开发服务，验证 TLS、Headers、401、413、SSRF、readiness 与 Collector 的安全路径。
- 进行静态密钥/私钥标记检查；未发现已跟踪真实私钥标记。专用 gitleaks/trufflehog 未安装，因此记录为 assurance gap。

Limitations and non-claims

- 本报告不是渗透测试认证、SOC 2/ISO 27001 合规结论或漏洞赏金保证。
- 未对外部生产资源、第三方账户、真实攻击性 Payload、密钥材料或破坏性动作进行测试。
- 当前没有外部 PostgreSQL/NATS/S3/KMS/SIEM 多节点环境，因此只评价适配、配置和故障测试，不声明生产容量/可用性。
- 当前开发环境 Sync V2 未全局启用；跨设备撤销、杀进程、Push 丢失和长离线需要授权多设备 E2E。
- 没有 Android 原生客户端；Android 只能评价协议准备度。
- 安全评分包含专业判断，应只随新证据改变。

Appendix — Executive action register

Blockers before broader exposure: ATH-SEC-2026-001 至 004。 **Blockers before distributed production:** ATH-SEC-2026-006、008 与外部 PG/NATS/S3/KMS 演练。 **Continuous governance:** dependency High burn-down、WS/Collector/AI adversarial tests、immutable evidence、incident runbooks。

Five-year blueprint: 统一身份与工作负载信任、可审计 AI 能力委托、全域 provenance/taint、客户/区域数据策略、可验证恢复、持续 Purple Team。Athena 不需要为了技术名词引入通用 Merkle/CRDT/ZKP；只有当明确威胁模型和协作需求出现时才增加复杂度。